

# Clase 290 — Certificaciones y desarrollo de carrera

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)<sup>2</sup> CISSP Official Study Guide y NICE Framework (NIST SP 800-181) 🕒 Duración estimada: **80 min** · Nivel: **Fundamentos**

## 🎯 Objetivo

Orientar tu carrera en ciberseguridad tras completar el programa: qué roles existen, qué certificaciones aportan valor real en cada etapa, cómo construir un plan de desarrollo profesional y un portfolio que demuestre competencia. Al terminar tendrás un mapa de roles y certificaciones, un plan personal a 12–24 meses y las bases para presentarte a empleadores con evidencia, no solo con títulos.

## 📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Ubicar** los roles de ciberseguridad (ofensivo, defensivo, GRC, cloud, appsec) y sus rutas.
2. **Seleccionar** certificaciones adecuadas a su etapa y objetivo.
3. **Diseñar** un plan de desarrollo profesional personal con hitos.
4. **Construir** un portfolio y perfil profesional que demuestre competencias.
5. **Preparar** una estrategia de estudio para una certificación concreta.

## 📖 Temas

| # | Tema                                   | Por qué importa                               |
|---|----------------------------------------|-----------------------------------------------|
| 1 | Mapa de roles (NICE Framework)         | Entender el terreno profesional               |
| 2 | Certificaciones por etapa              | Junior, intermedio, senior, gestión           |
| 3 | Rutas: ofensiva, defensiva, GRC, cloud | Elegir especialización                        |
| 4 | Portfolio y evidencia práctica         | Los labs y proyectos venden más que un título |
| 5 | Aprendizaje continuo (CPE)             | La ciberseguridad no para                     |
| 6 | Marca profesional y networking         | Visibilidad y oportunidades                   |
| 7 | Ética profesional                      | Códigos de conducta y responsabilidad         |

## 📖 Definiciones y características

- **NICE Framework:** marco de NIST que describe roles, tareas y competencias en ciberseguridad. *Clave:* lenguaje común para roles y planes de carrera.
- **Certificación fundacional:** valida bases (CompTIA Security+, GSEC). *Clave:* puerta de entrada, no meta final.
- **Certificación de especialización:** valida un dominio (OSCP ofensivo, CISSP gestión, CCSP cloud, CISA auditoría). *Clave:* elige según tu ruta.

- **CPE (Continuing Professional Education):** créditos de formación para mantener una certificación. *Clave:* obligan a aprender de forma continua.
- **Portfolio:** conjunto de evidencias (labs, writeups, proyectos, CTFs) que demuestran competencia. *Clave:* prueba práctica, no solo teoría.
- **Código de ética:** normas de conducta profesional (p. ej. el Canon de (ISC)<sup>2</sup>). *Clave:* su incumplimiento cuesta la certificación y la reputación.

## Herramientas y preparación

---

- El *NICE Framework* (NIST SP 800-181) para mapear roles y competencias.
- Plataformas de práctica: TryHackMe, Hack The Box, laboratorios propios (los de este programa).
- Un repositorio (GitHub/GitLab) para publicar writeups y proyectos como portfolio.
- Un perfil profesional actualizado (LinkedIn) y, si aplica, un blog técnico.
- Guías oficiales de las certificaciones objetivo (dominios y esquema de examen).

## Laboratorio guiado (ejercicio aplicado)

---

Vas a construir **tu plan de desarrollo profesional personal**.

1. **Autoevaluación:** usando las 14 partes del programa, puntúa de 1 a 5 tu nivel en 6 áreas (redes, ofensiva, defensiva/SOC, cloud, appsec, GRC). Identifica tus 2 fortalezas y 2 huecos.
2. **Elección de ruta:** decide una ruta principal (ofensiva / defensiva / GRC / cloud / appsec) y una secundaria, alineadas con tus fortalezas e intereses.
3. **Mapa de roles:** para tu ruta, identifica 3 roles objetivo (p. ej. GRC → analista de riesgo, auditor de seguridad, consultor de cumplimiento) y las competencias que exige cada uno según el NICE Framework.
4. **Plan de certificaciones:** define una secuencia realista a 24 meses. Ejemplo GRC: Security+ → CISA o ISO 27001 Lead Implementer → CISSP (con experiencia). Ejemplo ofensiva: Security+ → eJPT/PNPT → OSCP.
5. **Portfolio:** elige 3 laboratorios de este programa (p. ej. la matriz de riesgo de la clase 277, el SoA de la 278, el SBOM de la 284) y planifica publicarlos como writeups en tu repositorio.
6. **Plan de estudio:** para la primera certificación objetivo, desglosa los dominios del examen, asigna semanas de estudio y define cómo practicarás (labs, exámenes de prueba).
7. **Marca y red:** redacta tu titular profesional y 3 acciones de networking (comunidad, meetup, contribución open source).
8. **Ética:** lee un código de ética profesional (Canon de (ISC)<sup>2</sup>) y escribe cómo lo aplicarías ante un dilema real (encontrar una vulnerabilidad en producción sin autorización).

## Ejercicios

---

1. Mapea 3 roles del NICE Framework a las competencias que aportan las partes de este programa.
2. Compara CISSP y OSCP: propósito, formato y a quién sirven.
3. Diseña un plan de estudio de 8 semanas para Security+.
4. Elige 3 proyectos del curso y explica cómo los presentarías en una entrevista.
5. Redacta tu titular profesional y un resumen de 4 líneas para LinkedIn.
6. Analiza un dilema ético (bug bounty fuera de alcance) según un código de conducta.

## Reto verificable

Entrega tu **plan de desarrollo profesional personal** con: autoevaluación por áreas, ruta elegida, 3 roles objetivo con competencias NICE, secuencia de certificaciones a 24 meses, plan de estudio de la primera certificación desglosado por dominios y semanas, y un portfolio planificado con al menos 3 writeups de laboratorios del programa.

**Criterio de aceptación:** la ruta y las certificaciones son coherentes con las fortalezas de la autoevaluación, el plan de estudio tiene hitos temporales concretos, y el portfolio referencia labs reales del curso con evidencia publicable.

## Errores comunes

| Síntoma / mensaje                                   | Causa y cómo arreglar                                            |
|-----------------------------------------------------|------------------------------------------------------------------|
| Coleccionar certificaciones sin práctica            | El título sin evidencia convence poco; construye portfolio       |
| Empezar por una cert avanzada (OSCP/CISSP) sin base | Frustración y coste; sigue una secuencia por etapas              |
| Presentar CISSP sin la experiencia requerida        | Queda como "Associate" hasta cumplirla; planifica la experiencia |
| Portfolio vacío                                     | No demuestra competencia; publica writeups de tus labs           |
| Ignorar los CPE                                     | Puedes perder la certificación; planifica formación continua     |

## ? Preguntas frecuentes

? **¿Qué certificación hago primero?** Si empiezas, una fundacional como CompTIA Security+ da base y abre puertas. Después elige según tu ruta: OSCP (ofensiva), CISSP (gestión), CCSP (cloud), CISA (auditoría), ISO 27001 Lead (GRC).

? **¿Vale más un título o un portfolio?** Ambos suman, pero un portfolio con proyectos y writeups reales demuestra competencia práctica que un título por sí solo no garantiza. Combínalos.

? **¿Necesito CISSP para trabajar en GRC?** No para empezar. CISSP exige 5 años de experiencia y es un objetivo a medio plazo; antes puedes avanzar con Security+, CISA o certificaciones ISO 27001.

? **¿Cómo mantengo mis certificaciones?** Con créditos de formación continua (CPE): cursos, conferencias, publicaciones y contribuciones. Planifícalos a lo largo del año, no al final.

## Referencias

- NICE Framework — NIST SP 800-181 Rev.1. <https://csrc.nist.gov/pubs/sp/800/181/r1/final>
- (ISC)<sup>2</sup> — Certificaciones y Código de Ética. <https://www.isc2.org/>
- ISACA — CISA, CRISC y otras. <https://www.isaca.org/credentialing>
- CompTIA — Security+ y rutas de carrera. <https://www.comptia.org/certifications/security>

- Offensive Security — OSCP. <https://www.offsec.com/courses/pen-200/>

## **Siguiente clase**

---

Clase 291 - Introduccion a la seguridad de IA y ML